

Rocky Linux 10.2

human sanitization review

Step-by-step guide for the Endeavor GA corpus candidate. Review committed sanitized evidence only; do not recover or request raw scan output.

Purpose and decision boundary

This review is the human gate required before the Rocky Linux 10.2 container corpus can be considered for tested support. It does not by itself approve General Availability or change the compatibility matrix.

Stop and reject the candidate immediately if you find a real hostname, FQDN, address, MAC address, user identifier, package inventory, credential, token, private path, unexplained transformation, hash mismatch, schema failure, or golden mismatch.

1. Freeze the review scope

Work from the project root on the host. The worktree must be clean before you begin.

```
cd /home/elo/Work/Endeavor
git rev-parse HEAD
git status --short
```

Review only these retained artifacts:

- **PROVENANCE.md** - producer and evidence lineage
- **results.xml** - sanitized XCCDF Results
- **results.arf.xml** - sanitized ARF
- **results.oscal.json** and **results.arf.oscal.json** - conversion goldens

All are under `fixtures/ga-corpus/rocky-linux-10.2-x86_64/`. Raw hashes in the provenance record prove lineage and deletion; they do not authorize recovery of raw evidence.

2. Verify integrity

Calculate the retained artifact hashes and compare every value to the provenance table.

```
sha256sum \
fixtures/ga-corpus/rocky-linux-10.2-x86_64/results.xml \
fixtures/ga-corpus/rocky-linux-10.2-x86_64/results.arf.xml \
fixtures/ga-corpus/rocky-linux-10.2-x86_64/results.oscal.json \
fixtures/ga-corpus/rocky-linux-10.2-x86_64/results.arf.oscal.json
```

Verify the producer record names Rocky Linux 10.2 x86_64, OpenSCAP 1.4.4, the pinned base image and evaluator digests, source input hashes, hardened container boundary, expected exit status 2, and raw-output deletion statement.

3. Inspect the sanitized SCAP evidence

Run the local, schema-aware intake commands:

```
python3 -m endeavor inspect-xccdf \
--results fixtures/ga-corpus/rocky-linux-10.2-x86_64/results.xml

python3 -m endeavor inspect-arf \
--results fixtures/ga-corpus/rocky-linux-10.2-x86_64/results.arf.xml
```

Confirm the only target and execution values are canonical:

Category	Required canonical value
Target	endeavor-target
Identity	endeavor-fixture-user
IPv4	127.0.0.1
IPv6	0:0:0:0:0:0:1
MAC	00:00:00:00:00:00

Open both XML files in a text editor. Confirm that scanner metadata, CPEs, component and benchmark references, schema versions, timestamps needed for evidence, and rule outcomes remain intact. The fixed `/input/` paths are container paths and are allowed.

```
rg -n -i \
'localhost|hostname|fqdn|target-address|mac-address|mac_address|ip-v4|ip-v6|ip_address|identity|token|pass
word|secret|/home/' \
fixtures/ga-corpus/rocky-linux-10.2-x86_64/results.xml \
fixtures/ga-corpus/rocky-linux-10.2-x86_64/results.arf.xml
```

Every target-related match must be canonical or an explicitly documented, non-sensitive SCAP field. Do not approve generic rewriting of ARF identifiers, CPEs, or unrelated facts.

4. Verify the derived OSCAL goldens

```
python3 -m endeavor convert-xccdf \
--results fixtures/ga-corpus/rocky-linux-10.2-x86_64/results.xml \
--mapping fixtures/mappings/arf-xccdf-example-v1.json \
--output /tmp/endeavor-rocky-xccdf-review.json

python3 -m endeavor convert-arf-xccdf \
--results fixtures/ga-corpus/rocky-linux-10.2-x86_64/results.arf.xml \
--mapping fixtures/mappings/arf-xccdf-example-v1.json \
--output /tmp/endeavor-rocky-arf-review.json

cmp /tmp/endeavor-rocky-xccdf-review.json \
fixtures/ga-corpus/rocky-linux-10.2-x86_64/results.oscal.json
cmp /tmp/endeavor-rocky-arf-review.json \
fixtures/ga-corpus/rocky-linux-10.2-x86_64/results.arf.oscal.json
```

Both cmp commands must return silently with exit status 0. Remove only the two temporary review JSON files when you finish.

5. Record the decision

Add the following entry to PROVENANCE.md in a review pull request. Do not update the compatibility matrix yet.

```
Human sanitization review
- Reviewer: <name or approved reviewer identifier>
- Date (UTC): <YYYY-MM-DD>
- Decision: approved | rejected
- Evidence reviewed: all four retained artifacts
- Integrity: all four retained SHA-256 values matched
- Sensitive-data review: canonical target, identity, address, and MAC values confirmed
- SCAP preservation: identifiers, CPEs, references, schema versions, and rule results confirmed
- Notes: <none or concise rejection reason>
```

Approval means only that the Rocky evidence is sanitized and fit for GA corpus admission. The platform remains outside the tested compatibility matrix until the GA acceptance record includes it and the Ubuntu corpus gate is complete.

Completion checklist

- Worktree, artifacts, hashes, and provenance verified
- No unnecessary host or sensitive data found
- SCAP identifiers, CPEs, references, schema versions, and result status preserved
- Both OSCAL conversions match committed golden outputs
- Reviewer identity, UTC date, decision, and notes recorded in a review change